

Due-Diligence Report: repo_4

Self-audit passed — every finding this report gathered is cited below.

Verdict: 4/10 — Est. 15-29 engineer-hours to acquisition-ready

repo_4 installs successfully but test collection fails due to an import error. 5 vulnerable packages were detected across 64 CVEs, and 1 copyleft license conflict was found in gnureadline. Total remediation cost is estimated at 22 hours (range 15-29h).

Remediation Cost Estimate

Item	Hours	Basis
Upgrade 5 vulnerable dependencies	10	2h per package (research safe upgrade + apply + regression test)
Stand up a working automated test suite	8	Flat estimate — tests did not run successfully during audit
Resolve 1 copyleft license conflict(s)	4	4h per conflict (legal review + find/swap alternative dependency)

Total: 22 hours (range: 15-29h)

Heuristic estimate based on the stated per-item assumptions above, not a professional engineering quote. Presented as a range (15-29h) to avoid false precision. Does not include general code-quality improvements beyond the specific findings listed.

Risks

- Vulnerable dependency package Flask identified with 8 vulnerability findings.
Vulnerability scan: package Flask version 0.10.1 has vulnerability count 8.
- Vulnerable dependency package Jinja2 identified with 14 vulnerability findings.
Vulnerability scan: package Jinja2 version 2.7.3 has vulnerability count 14.
- Vulnerable dependency package Werkzeug identified with 24 vulnerability findings.
Vulnerability scan: package Werkzeug version 0.9.6 has vulnerability count 24.
- Vulnerable dependency package requests identified with 12 vulnerability findings.
Vulnerability scan: package requests version 2.3.0 has vulnerability count 12.
- Vulnerable dependency package gunicorn identified with 6 vulnerability findings.
Vulnerability scan: package gunicorn version 18.0 has vulnerability count 6.
- License conflict: package gnureadline uses copyleft license GPL-3.0-or-later.
License check: conflicts: [{package: gnureadline, license: GPL-3.0-or-later}].
- Test suite collection failed.
Build/test evidence: install_ok: false, tests_ran: false, ERROR test/test_endpoints.py.

Strengths

- All 11 declared dependencies are pinned.

Dependency evidence: unpinned_count: 0, total_declared: 11, manifest_type: requirements.txt.

- Active GitHub issue and merge activity.

GitHub activity: open_issue_count_sampled: 20, recent_merge_count_sampled: 13.

License

Project license: **not found**

Dependencies checked: 11, conflicts: 1, unknown license: 5

- gnureadline — GPL-3.0-or-later (copyleft)

Ownership & Continuity Risk

8 contributor(s), top contributor: 41.9% of commits, last push: 58 days ago

Could Not Verify

- Project license terms because project_license found is false.
- 5 dependency licenses due to missing PyPI metadata.

Every claim above is backed by evidence in the full JSON report.